

Question 1: Shannon Entropy

A source emits four symbols {A, B, C, D} with probabilities:

$$P(A) = 0.5$$

$$P(B) = 0.25$$

$$P(C) = 0.125$$

$$P(D) = 0.125$$

Calculate the entropy H of this source.

Answer:

The formula for Shannon entropy is:

$$H = - \sum p_i \log_2(p_i)$$

Now calculate each term:

- For A: $-0.5 \log_2(0.5) = -0.5 \times (-1) = 0.5$
- For B: $-0.25 \log_2(0.25) = -0.25 \times (-2) = 0.5$
- For C: $-0.125 \log_2(0.125) = -0.125 \times (-3) = 0.375$
- For D: $-0.125 \log_2(0.125) = -0.125 \times (-3) = 0.375$

Now add them:

$$H = 0.5 + 0.5 + 0.375 + 0.375$$

$$H = 1.75 \text{ bits/symbol}$$

Final Answer:

$$H = 1.75 \text{ bits/symbol}$$

Question 2: Unicity Distance

Given a language with an entropy of $R_L = 1.5$ bits/letter and a character set of 26 letters, where:

$$H_0 = \log_2(26) \approx 4.7 \text{ bits}$$

Calculate the unicity distance U for a cipher with a key space of 2^{56} .

Answer:

The unicity distance formula is:

$$U = K / D$$

where:

K = key entropy

D = language redundancy

First calculate redundancy:

$$D = H_0 - R_L$$

$$D = 4.7 - 1.5$$

$$D = 3.2 \text{ bits/letter}$$

The key space is 2^{56} , so:

$$K = 56 \text{ bits}$$

Now calculate U:

$$U = 56 / 3.2$$

$$U = 17.5 \text{ characters}$$

Final Answer:

$$U = 17.5 \text{ characters}$$

This means that after about 18 characters, a unique solution is likely to exist.

Question 3: RSA Key Generation

Choose $p = 11$ and $q = 13$. If the public exponent $e = 7$, calculate the private key d .

Answer:

First calculate n :

$$n = p \times q$$

$$n = 11 \times 13$$

$$n = 143$$

Now calculate Euler's totient:

$$\phi(n) = (p - 1)(q - 1)$$

$$\phi(n) = 10 \times 12$$

$$\phi(n) = 120$$

The private key d must satisfy:

$$d \times e \equiv 1 \pmod{\phi(n)}$$

So:

$$7d \equiv 1 \pmod{120}$$

Using the Extended Euclidean Algorithm:

$$120 = 17 \times 7 + 1$$

So:

$$1 = 120 - 17 \times 7$$

This means:

$$d \equiv -17 \pmod{120}$$

$$d = 103$$

Final Answer:

Private key $d = 103$

Question 4: RSA Encryption

Using the keys from Question 3, where $n = 143$ and $e = 7$, encrypt the message $M = 9$.

Answer:

The RSA encryption formula is:

$$C = M^e \pmod{n}$$

Substitute the values:

$$C = 9^7 \pmod{143}$$

Calculate powers:

$$9^1 = 9$$

$$9^2 = 81$$

$$9^4 = 81^2 = 6561$$

Now reduce modulo 143:

$$6561 \pmod{143} = 126$$

Now:

$$9^7 = 9^4 \times 9^2 \times 9^1$$

$$9^7 \pmod{143} = 126 \times 81 \times 9 \pmod{143}$$

$$126 \times 81 \times 9 = 91854$$

$$91854 \pmod{143} = 48$$

Final Answer:

$$C = 48$$

Question 5: Diffie-Hellman Key Exchange

Alice and Bob use $p = 23$ and $g = 5$. Alice chooses $a = 6$. Bob chooses $b = 15$. Find the shared secret K .

Answer:

Alice calculates:

$$A = g^a \bmod p$$

$$A = 5^6 \bmod 23$$

$$5^6 = 15625$$

$$15625 \bmod 23 = 8$$

So Alice sends:

$$A = 8$$

Bob calculates:

$$B = g^b \bmod p$$

$$B = 5^{15} \bmod 23$$

$$B = 19$$

So Bob sends:

$$B = 19$$

Alice computes the shared secret:

$$K = B^a \bmod p$$

$$K = 19^6 \bmod 23$$

$$K = 2$$

Bob computes the shared secret:

$$K = A^b \bmod p$$

$$K = 8^{15} \bmod 23$$

$$K = 2$$

Final Answer:

Shared secret $K = 2$

Question 6: Brute Force Complexity

A password is exactly 8 characters long, using uppercase letters, lowercase letters, and digits. If an attacker can test 10^9 passwords per second, what is the maximum time to crack it?

Answer:

The character set contains:

26 uppercase letters

26 lowercase letters

10 digits

So:

$$S = 26 + 26 + 10$$

$$S = 62$$

Total possible passwords:

$$N = 62^8$$

$$N = 218,340,105,584,896$$

Now calculate time:

$$\text{Time} = N / 10^9$$

$$\text{Time} = 218,340.105584896 \text{ seconds}$$

Convert seconds to hours:

$$\text{Time} = 218,340.105584896 / 3600$$

$$\text{Time} \approx 60.65 \text{ hours}$$

Final Answer:

Maximum time ≈ 60.65 hours

Question 7: Avalanche Effect

In a block cipher, changing 1 bit of plaintext results in an average of 32 bits of a 64-bit ciphertext changing. Calculate the Hamming distance and the percentage change.

Answer:

The Hamming distance is the number of changed bits.

$$\text{Hamming Distance} = 32$$

Percentage change:

$$\text{Percentage} = (32 / 64) \times 100$$

$$\text{Percentage} = 50\%$$

Final Answer:

$$\text{Hamming Distance} = 32 \text{ bits}$$

$$\text{Percentage change} = 50\%$$

This represents an ideal avalanche effect.

Question 8: Double DES and Meet-in-the-Middle Attack

If DES has a key size of 56 bits, what is the effective security of Double DES against a Meet-in-the-Middle attack?

Answer:

Double DES uses two DES keys.

Total key size without attack:

$$56 + 56 = 112 \text{ bits}$$

However, Meet-in-the-Middle attack reduces the effective security.

The attack requires approximately:

$$2 \times 2^{56} \text{ operations}$$

This is equivalent to:

$$2^{57} \text{ operations}$$

Final Answer:

Effective security = 57 bits

It is not 112 bits because of the Meet-in-the-Middle attack.

Question 9: Known Plaintext Attack on Hill Cipher

In a 2×2 Hill Cipher, plaintext HI, represented as (7, 8), maps to ciphertext XY, represented as (23, 24). Also, plaintext NO, represented as (13, 14), maps to ciphertext QW, represented as (16, 22). Set up the matrix equation to find the key K.

Answer:

The plaintext matrix is:

$$P = \begin{bmatrix} 7 & 13 \\ 8 & 14 \end{bmatrix}$$

The ciphertext matrix is:

$$C = \begin{bmatrix} 23 & 16 \\ 24 & 22 \end{bmatrix}$$

The Hill Cipher equation is:

$$K \times P = C \text{ mod } 26$$

To solve for K:

$$K = C \times P^{-1} \text{ mod } 26$$

Now check if P is invertible.

$$\det(P) = (7 \times 14) - (13 \times 8)$$

$$\det(P) = 98 - 104$$

$$\det(P) = -6$$

Now reduce modulo 26:

$$-6 \bmod 26 = 20$$

Check gcd:

$$\gcd(20, 26) = 2$$

Since $\gcd(20, 26)$ is not 1, the matrix P is not invertible modulo 26.

Final Answer:

The matrix equation is:

$$K \times P = C \bmod 26$$

But P is not invertible modulo 26, so this pair of plaintext-ciphertext examples cannot be used to find a unique key K.

Question 10: Discrete Logarithm Problem

Solve for x:

$$3^x \equiv 13 \bmod 17$$

Answer:

Test powers of 3 modulo 17:

$$3^1 = 3$$

$$3^2 = 9$$

$$3^3 = 27$$

$$27 \bmod 17 = 10$$

$$3^4 = 3 \times 10 = 30$$

$$30 \bmod 17 = 13$$

So:

$$3^4 \equiv 13 \bmod 17$$

Final Answer:

$$x = 4$$

Question 11: Single Loss Expectancy

An e-commerce server is worth \$10,000. A successful SQL injection attack results in a 20% loss of asset value. Calculate the Single Loss Expectancy.

Answer:

Formula:

$SLE = \text{Asset Value} \times \text{Exposure Factor}$

Substitute the values:

$SLE = 10,000 \times 0.20$

$SLE = 2,000$

Final Answer:

$SLE = \$2,000$

Question 12: Annualized Loss Expectancy

If the SQL injection attack from Question 11 is expected to occur once every 4 months, calculate the Annualized Loss Expectancy.

Answer:

Formula:

$ALE = SLE \times ARO$

The attack occurs once every 4 months.

There are 12 months in a year.

$ARO = 12 / 4$

$ARO = 3$

Now:

$ALE = 2,000 \times 3$

$ALE = 6,000$

Final Answer:

$ALE = \$6,000$ per year

Question 13: Cost-Benefit Analysis

A firewall costs \$4,000 per year to maintain. It is expected to reduce the ALE in Question 12 by 80%. Is the investment justified?

Answer:

Current ALE:

$ALE = \$6,000$

The firewall reduces ALE by 80%.

Reduced ALE:

$\text{Reduced ALE} = 6,000 \times (1 - 0.80)$

$$\text{Reduced ALE} = 6,000 \times 0.20$$

$$\text{Reduced ALE} = 1,200$$

Savings:

$$\text{Savings} = 6,000 - 1,200$$

$$\text{Savings} = 4,800$$

Net benefit:

$$\text{Net Benefit} = \text{Savings} - \text{Cost}$$

$$\text{Net Benefit} = 4,800 - 4,000$$

$$\text{Net Benefit} = 800$$

Final Answer:

Yes, the investment is justified.

$$\text{Net benefit} = \$800$$

Question 14: Quantitative Risk Probability

A system has three independent security controls with failure probabilities 0.1, 0.05, and 0.2. What is the probability that at least one control fails?

Answer:

Formula:

$$P(\text{at least one fails}) = 1 - P(\text{all succeed})$$

Success probabilities:

$$\text{Control 1 success} = 1 - 0.1 = 0.9$$

$$\text{Control 2 success} = 1 - 0.05 = 0.95$$

$$\text{Control 3 success} = 1 - 0.2 = 0.8$$

Now:

$$P(\text{all succeed}) = 0.9 \times 0.95 \times 0.8$$

$$P(\text{all succeed}) = 0.684$$

Therefore:

$$P(\text{at least one fails}) = 1 - 0.684$$

$$P(\text{at least one fails}) = 0.316$$

Final Answer:

$$\text{Probability} = 0.316$$

$$\text{Percentage} = 31.6\%$$

Question 15: Return on Security Investment

Using the formula:

$$\text{ROSI} = [(\text{ALE}_{\text{unprotected}} - \text{ALE}_{\text{protected}}) - \text{Cost}] / \text{Cost}$$

Find ROSI for Question 13.

Answer:

$$\text{ALE}_{\text{unprotected}} = 6,000$$

$$\text{ALE}_{\text{protected}} = 1,200$$

$$\text{Cost} = 4,000$$

Now:

$$\text{ROSI} = [(6,000 - 1,200) - 4,000] / 4,000$$

$$\text{ROSI} = [4,800 - 4,000] / 4,000$$

$$\text{ROSI} = 800 / 4,000$$

$$\text{ROSI} = 0.2$$

Convert to percentage:

$$0.2 \times 100 = 20\%$$

Final Answer:

$$\text{ROSI} = 0.2 \text{ or } 20\%$$

Question 16: MTBF and Availability

A server has a Mean Time Between Failures, MTBF, of 2,000 hours and a Mean Time To Repair, MTTR, of 5 hours. Calculate the availability.

Answer:

Formula:

$$\text{Availability} = \text{MTBF} / (\text{MTBF} + \text{MTTR})$$

Substitute the values:

$$\text{Availability} = 2000 / (2000 + 5)$$

$$\text{Availability} = 2000 / 2005$$

$$\text{Availability} \approx 0.9975$$

Convert to percentage:

$$0.9975 \times 100 = 99.75\%$$

Final Answer:

Availability $\approx$ 0.9975 or 99.75%

Question 17: Redundant Systems

Two identical firewalls are placed in parallel. If one fails, the other takes over. Each firewall has an availability of 0.95. Calculate the total availability.

Answer:

For parallel systems:

$$A_{\text{total}} = 1 - [(1 - A_1)(1 - A_2)]$$

Here:

$$A_1 = 0.95$$

$$A_2 = 0.95$$

So:

$$A_{\text{total}} = 1 - [(1 - 0.95)(1 - 0.95)]$$

$$A_{\text{total}} = 1 - (0.05 \times 0.05)$$

$$A_{\text{total}} = 1 - 0.0025$$

$$A_{\text{total}} = 0.9975$$

Final Answer:

Total availability = 0.9975 or 99.75%

Question 18: Series Systems

A secure connection requires a VPN with availability 0.99, a Gateway with availability 0.98, and an App Server with availability 0.99. All must be functional. Calculate the system availability.

Answer:

For a series system:

$$A_{\text{series}} = A_1 \times A_2 \times A_3$$

Substitute the values:

$$A_{\text{series}} = 0.99 \times 0.98 \times 0.99$$

$$A_{\text{series}} = 0.960498$$

Rounded:

$$A_{\text{series}} \approx 0.9605$$

Convert to percentage:

$$0.9605 \times 100 = 96.05\%$$

Final Answer:

System availability $\approx$ 0.9605 or 96.05%

Question 19: Downtime Calculation

A system guarantees “Four Nines” availability, which is 99.99%. Calculate the maximum allowed downtime per year, assuming 365 days.

Answer:

Total minutes in one year:

$$365 \times 24 \times 60 = 525,600 \text{ minutes}$$

$$\text{Availability} = 99.99\% = 0.9999$$

Downtime fraction:

$$1 - 0.9999 = 0.0001$$

Downtime:

$$525,600 \times 0.0001 = 52.56 \text{ minutes}$$

Final Answer:

Maximum downtime = 52.56 minutes per year

Question 20: Bell-LaPadula Access Control

A subject S has Secret clearance. Objects O1 and O2 exist:

O1 = Top Secret

O2 = Confidential

According to the “No Read Up” and “No Write Down” rules, which operations are allowed?

Answer:

Bell-LaPadula focuses on confidentiality.

Rule 1: No Read Up

A subject cannot read data at a higher classification level.

Rule 2: No Write Down

A subject cannot write data to a lower classification level.

The subject has Secret clearance.

For reading:

- S can read O2 because Confidential is below Secret.
- S cannot read O1 because Top Secret is above Secret.

For writing:

- S can write to O1 because Top Secret is above Secret.
- S cannot write to O2 because Confidential is below Secret.

Final Answer:

Allowed:

- Read O2
- Write O1

Not allowed:

- Read O1
- Write O2

Question 21: Packet Filtering Throughput

An IDS processes packets at 1.5 Gbps. If the average packet size is 500 bytes, how many packets per second can it handle?

Answer:

Convert Gbps to bits per second:

$$1.5 \text{ Gbps} = 1.5 \times 10^9 \text{ bits/second}$$

Convert packet size to bits:

$$500 \text{ bytes} = 500 \times 8 \text{ bits}$$

$$500 \text{ bytes} = 4000 \text{ bits}$$

Now calculate packets per second:

$$\text{pps} = 1.5 \times 10^9 / 4000$$

$$\text{pps} = 375,000$$

Final Answer:

The IDS can handle 375,000 packets per second.

Question 22: HMAC Calculation Logic

In HMAC, the inner hash is:

$$H(K \text{ XOR } \text{ipad} \parallel M)$$

If ipad is 0x36 and K is 0xAA, what is the first byte of the XOR result?

Answer:

Write both values in binary:

0xAA = 1010 1010

0x36 = 0011 0110

Now XOR them:

1010 1010

XOR 0011 0110

= 1001 1100

Binary 1001 1100 equals hexadecimal 0x9C.

Final Answer:

First byte of XOR result = 0x9C

Question 23: DoS Attack Bandwidth

A botnet of 10,000 nodes targets a server. Each node sends 512 Kbps of traffic. What is the total attack volume in Gbps?

Answer:

Each node sends:

512 Kbps = 512,000 bits/second

Total traffic:

$10,000 \times 512,000 = 5,120,000,000$ bits/second

Convert to Gbps:

$5,120,000,000 / 10^9 = 5.12$ Gbps

Final Answer:

Total attack volume = 5.12 Gbps

Question 24: IPsec Overhead

An original IP packet is 1000 bytes. Using ESP in Tunnel Mode adds:

20-byte IP header

8-byte ESP header

16-byte IV

12-byte ICV

Calculate the total overhead percentage.

Answer:

Total overhead:

$$20 + 8 + 16 + 12 = 56 \text{ bytes}$$

Original packet size:

1000 bytes

Overhead percentage relative to the original packet:

$$\text{Overhead Percentage} = (56 / 1000) \times 100$$

$$\text{Overhead Percentage} = 5.6\%$$

Total packet size:

$$1000 + 56 = 1056 \text{ bytes}$$

Final Answer:

Total overhead = 56 bytes

Overhead percentage = 5.6%

Total packet size = 1056 bytes

Question 25: False Acceptance Rate

A biometric system has a False Acceptance Rate of 0.01% and a False Rejection Rate of 1%. In a population of 1,000,000 unauthorized users, how many are expected to gain access?

Answer:

$$\text{FAR} = 0.01\%$$

Convert to decimal:

$$0.01\% = 0.0001$$

Unauthorized users:

1,000,000

Expected false acceptances:

$$1,000,000 \times 0.0001 = 100$$

Final Answer:

Expected unauthorized users gaining access = 100

Question 26: Lattice-Based Access Control

A system uses labels {L, C}, where L is a linear hierarchy:

Public < Internal < Secret

and C is a set of categories:

{Finance, HR}

Is a subject with label:

(Secret, {Finance})

allowed to read an object with label:

(Internal, {Finance, HR})?

Answer:

In lattice-based access control, a subject can read an object only if the subject dominates the object.

A subject dominates an object if:

1. The subject's security level is greater than or equal to the object's security level.
2. The object's categories are a subset of the subject's categories.

Now compare levels:

Subject level = Secret

Object level = Internal

Secret is higher than Internal, so the level condition is satisfied.

Now compare categories:

Subject categories = {Finance}

Object categories = {Finance, HR}

For access to be allowed:

{Finance, HR} must be a subset of {Finance}

This is false because HR is not included in the subject's category set.

Final Answer:

No, access is not allowed.

Reason: The subject does not have the HR category.

Question 27: Database Inference Using a Tracker

A database allows queries only if they return results for at least 3 records. Total records $N = 100$. If a query for "Salary > 100k" returns 2, it is blocked. If a tracker query T returns 50, and "T AND Salary > 100k" returns 48, what is the count for "Salary > 100k"?

Corrected Answer:

Let:

$S = \text{Salary} > 100k$

Given:

$\text{Count}(S) = 2$, but this direct query is blocked because it returns fewer than 3 records.

Also given:

$\text{Count}(T) = 50$

$\text{Count}(T \text{ AND } S) = 48$

From these two tracker values, we can calculate:

$\text{Count}(T \text{ AND NOT } S) = \text{Count}(T) - \text{Count}(T \text{ AND } S)$

$\text{Count}(T \text{ AND NOT } S) = 50 - 48$

$\text{Count}(T \text{ AND NOT } S) = 2$

However, this does not logically give the total $\text{Count}(S)$. It only gives the number of records inside T that do not satisfy S.

The question already states that $\text{Count}(S) = 2$, but the tracker values given do not prove that result.

Final Answer:

The count for “Salary > 100k” is 2 only because the question directly states it.

But from the tracker values alone, the valid calculation is:

$\text{Count}(T \text{ AND NOT Salary} > 100k) = 2$

So the original tracker explanation needs correction.

Question 28: Buffer Overflow Address Calculation

A buffer starts at address 0xBFFF0000 and is 64 bytes long. The return address of the function is stored at 0xBFFF0048. How many bytes of padding are needed before the malicious return address can be written?

Answer:

Calculate the offset:

$\text{Offset} = \text{Return Address} - \text{Buffer Start}$

$\text{Offset} = 0xBFFF0048 - 0xBFFF0000$

$\text{Offset} = 0x48$

Convert 0x48 to decimal:

$0x48 = 4 \times 16 + 8$

$0x48 = 64 + 8$

$0x48 = 72$

Final Answer:

Padding needed = 72 bytes

Question 29: Digital Signatures and Hashing

If a collision attack on SHA-256 requires 2^{128} operations, and a pre-image attack requires 2^{256} operations, how much more difficult is the pre-image attack?

Answer:

Difficulty ratio:

$$\text{Difficulty Ratio} = 2^{256} / 2^{128}$$

Using exponent rules:

$$2^{256} / 2^{128} = 2^{(256 - 128)}$$

$$2^{128}$$

Final Answer:

A pre-image attack is 2^{128} times more difficult than a collision attack.

Question 30: Multi-Level Security Using Biba Model

The Biba Integrity Model uses “No Read Down” and “No Write Up.” If User A has integrity level High and User B has integrity level Low, can User B modify User A’s files? Can User A read User B’s files?

Answer:

The Biba model protects integrity.

Rule 1: No Read Down

A high-integrity subject cannot read low-integrity data.

Rule 2: No Write Up

A low-integrity subject cannot write to high-integrity data.

User A has High integrity.

User B has Low integrity.

Can User B modify User A’s files?

No.

Reason:

User B is Low, and User A’s files are High. Under “No Write Up,” a Low-integrity user cannot write to a High-integrity object.

Can User A read User B’s files?

No.

Reason:

User A is High, and User B's files are Low. Under "No Read Down," a High-integrity user cannot read Low-integrity data because it could contaminate high-integrity information.

Final Answer:

User B cannot modify User A's files.

User A cannot read User B's files.